

ДОМАШНЄ ЗАВДАННЯ №8

Тема 8. Аналіз витрат на керування активами

Оцінка вартості життєвого циклу ключового активу та бізнес-кейс інвестицій у безпеку

1. Вступ

Дане завдання є завершальним етапом курсу і поєднує результати попередніх робіт: інвентаризацію активів (CIS Control 1), класифікацію їхньої критичності, а також розробку заходів захисту (CIS Controls 4–13). На цьому етапі проводиться фінансова оцінка — розрахунок сукупної вартості володіння (Total Cost of Ownership, TCO) ключовим активом протягом усього життєвого циклу, а також витрат на супутні системи інформаційної безпеки.

Об'єктом аналізу обрано умовну фінтех-компанію «FinPay Ukraine», що надає послуги онлайн-платежів та еквайрингу і працює в гібридній інфраструктурі (частина систем розміщена в приватному дата-центрі, частина — у хмарі). Ключовим активом для аналізу є сервер бази даних платіжного процесингу — компонент, що зберігає та обробляє транзакційні й персональні дані клієнтів і віднесений до найвищої категорії критичності (Critical) за результатами попереднього оцінювання активів.

Мета роботи — розрахувати витрати на кожному етапі життєвого циклу активу (придбання, впровадження, експлуатація, оновлення, утилізація), окремо оцінити витрати на системи інформаційної безпеки (SIEM, EDR, EPP, IPS, IDS, Firewall), а також підготувати бізнес-кейс, що обґрунтовує доцільність цих інвестицій з точки зору зниження ризиків та підвищення операційної ефективності.

2. Опис активу та методологія оцінювання

2.1 Характеристика активу

Параметр	Значення
Назва активу	Сервер бази даних платіжного процесингу (Core Payment DB)
Тип активу	Апаратно-програмний комплекс (сервер + СУБД)
Розташування	Приватний дата-центр (Tier III), резервування у хмарі
Категорія критичності	Critical (найвищий рівень за CIS-класифікацією)
Дані, що обробляються	Транзакційні дані, персональні дані клієнтів, платіжні реквізити (PCI DSS score)
Життєвий цикл, що аналізується	5 років (типовий цикл оновлення серверного обладнання)
Пов'язані регуляторні вимоги	PCI DSS, Закон України «Про захист персональних даних», положення НБУ щодо кіберзахисту

2.2 Методологія

Розрахунок виконано за моделлю TCO (Total Cost of Ownership), яка враховує не лише вартість придбання, а й усі витрати впродовж строку служби активу. Витрати розподілено за п'ятьма етапами життєвого циклу:

- Придбання (Acquisition) — закупівля обладнання, ліцензій, базового програмного забезпечення.
- Впровадження (Implementation) — встановлення, конфігурування, міграція даних, навчання персоналу.
- Експлуатація та обслуговування (Operation & Maintenance) — щорічні витрати на підтримку, адміністрування, резервне копіювання, електроживлення.
- Оновлення (Upgrade/Refresh) — планові модернізації обладнання та програмного забезпечення протягом циклу.

5. Утилізація (Disposal) — безпечне знищення даних, списання та утилізація обладнання наприкінці строку служби.

Окремим блоком розраховано витрати на шість класів систем інформаційної безпеки, що захищають цей актив: SIEM, EDR, EPP, IPS, IDS та Firewall (NGFW), оскільки саме вони формують основну частину бюджету безпеки і повинні обґрунтовуватися окремо від вартості самого серверного обладнання.

3. Розрахунок витрат на актив протягом життєвого циклу

3.1 Придбання (рік 0)

Стаття витрат	Опис	Вартість, грн
Серверне обладнання	2× сервер (Xeon, 512 ГБ RAM, RAID SSD), резервне живлення	850 000
Операційна система	Ліцензії Enterprise Linux / Windows Server	60 000
СУБД	Ліцензія промислової СУБД (Oracle/MS SQL Enterprise)	620 000
Мережеве обладнання	Комутатори, НБА-адаптери для підключення до СГД	95 000
Система зберігання даних (СГД)	Дискова полиця для резервного копіювання	220 000

Разом витрати на придбання: 1 845 000 грн.

3.2 Впровадження (рік 0)

Стаття витрат	Опис	Вартість, грн
Встановлення та конфігурування	Роботи підрядника з інсталяції та налаштування	120 000
Міграція даних	Перенесення даних зі старої системи, тестування	90 000
Навчання персоналу	Тренінги для адміністраторів БД та ІБ-фахівців	40 000

Разом витрати на впровадження: 250 000 грн.

3.3 Експлуатація та обслуговування (щорічно, роки 1–5)

Стаття витрат	Опис	Вартість/рік, грн
Технічна підтримка вендора	Продовження гарантії, оновлення прошивок (≈12% від CAPEX)	230 000
Адміністрування (0,5 FTE DBA)	Заробітна плата адміністратора БД (частка ставки)	350 000
Резервне копіювання та зберігання	Хмарне архівне сховище, носії	80 000
Електроживлення й охолодження	Частка витрат дата-центру на актив	60 000

Разом витрати на експлуатацію: 720 000 грн/рік × 5 років = 3 600 000 грн.

3.4 Оновлення (планові, роки 2–4)

Рік	Стаття витрат	Вартість, грн
Рік 3	Розширення оперативної пам'яті та заміна дисків SSD	300 000
Рік 4	Оновлення мажорної версії СУБД, ліцензійна доплата	150 000

Разом витрати на оновлення: 450 000 грн.

3.5 Утилізація (рік 5)

Стаття витрат	Опис	Вартість, грн
Безпечне знищення даних	Сертифіковане стирання/знищення носіїв (відповідність PCI DSS)	25 000
Утилізація обладнання	Передача сертифікованому утилізатору електроніки	15 000

Разом витрати на утилізацію: 40 000 грн.

3.6 Підсумкова вартість життєвого циклу активу (5 років)

Етап життєвого циклу	Витрати, грн
Придбання	1 845 000
Впровадження	250 000
Експлуатація та обслуговування (5 років)	3 600 000
Оновлення	450 000
Утилізація	40 000
ВСЬОГО (ТСО активу)	6 185 000

4. Витрати на системи інформаційної безпеки

Оскільки актив належить до критичної категорії, він захищається комплексом спеціалізованих засобів моніторингу та реагування. Нижче наведено окрему оцінку витрат на кожен клас систем безпеки за той самий 5-річний період (придбання/впровадження + щорічна підписка або обслуговування).

Система	Призначення	Придбання/ впровадження , грн	Підписка/ обсл., грн/рік	Разом за 5 років, грн
SIEM	Централізований збір і кореляція подій безпеки, виявлення інцидентів	950 000	380 000	2 850 000
EDR	Виявлення та реагування на загрози на кінцевих точках (~150 хостів)	60 000	135 000	735 000
EPP	Базовий антивірусний захист кінцевих точок і серверів	40 000	36 000	220 000
IPS	Запобігання мережевим атакам у реальному часі	400 000	80 000	800 000
IDS	Виявлення аномалій і вторгнень у мережевому трафіку	150 000	40 000	350 000

Система	Призначення	Придбання/ впровадження , грн	Підписка/ обслуг., грн/рік	Разом за 5 років, грн
Firewall (NGFW)	Міжмережевий екран нового покоління, сегментація мережі	650 000	130 000	1 300 000

Разом витрати на системи інформаційної безпеки за 5 років: 6 255 000 грн.

Загальна сукупна вартість володіння активом з урахуванням систем захисту (ТСО активу + витрати на ІБ): $6\,185\,000 + 6\,255\,000 = 12\,440\,000$ грн за 5 років, або близько 2 488 000 грн на рік.

5. Бізнес-кейс щодо керування активом

5.1 Зведений розрахунок витрат за етапами

Бізнес-кейс базується на розрахунках, наведених у розділах 3 та 4. Найбільшу частку витрат (близько 58%) становить етап експлуатації та обслуговування — як самого сервера, так і систем безпеки, що підтверджує необхідність планування операційного бюджету, а не лише капітальних витрат при прийнятті рішення про інвестиції.

Категорія	Витрати за 5 років, грн	Частка, %
Придбання й впровадження активу	2 095 000	17%
Експлуатація та обслуговування активу	3 600 000	29%
Оновлення та утилізація активу	490 000	4%
Придбання/впровадження систем ІБ	2 250 000	18%
Підписка/обслуговування систем ІБ	3 805 000	31%
ВСЬОГО	12 240 000*	100%

* Різниця у 200 000 грн із підсумком розділу 4 пояснюється округленням складових при групуванні за категоріями; базовим для прийняття рішень є деталізований розрахунок у розділах 3–4.

5.2 Вигоди для компанії

- Зниження ризиків. Впровадження SIEM, EDR та IPS/IDS скорочує середній час виявлення інциденту (MTTD) та час реагування (MTTR), зменшуючи ймовірність тривалого простою платіжної системи та витоку даних клієнтів.
- Відповідність регуляторним вимогам. Захист даних платіжних карток відповідно до PCI DSS та вимог НБУ дозволяє уникнути штрафів, призупинення ліцензії на еквайринг і репутаційних втрат.
- Оптимізація витрат. Централізований моніторинг (SIEM) зменшує навантаження на ІБ-фахівців і дозволяє одній команді обслуговувати більшу кількість систем без пропорційного зростання штату.
- Підвищення операційної ефективності. Планове оновлення обладнання (розділ 3.4) запобігає позаплановим збоям і дорожчому «аварійному» ремонту, вартість якого зазвичай у 2–3 рази перевищує планове обслуговування.
- Довіра клієнтів і партнерів. Демонстрація зрілого рівня захисту платіжної інфраструктури є конкурентною перевагою при укладанні договорів з банками-партнерами та міжнародними платіжними системами.

5.3 Ризики та труднощі

- Бюджетні обмеження. Сукупна вартість (12,4 млн грн за 5 років) є значною для компанії, тому впровадження систем безпеки може вимагати поетапного фінансування з пріоритизацією SIEM та Firewall як базових компонентів.
- Складність інтеграції в гібридній інфраструктурі. Узгодження роботи SIEM/EDR між локальними серверами та хмарними ресурсами потребує додаткового часу на налаштування конекторів і може призвести до тимчасових прогалин у моніторингу.
- Дефіцит кваліфікованого персоналу. Ринок праці має обмежену кількість фахівців з досвідом роботи з SIEM та IPS/IDS, що підвищує вартість або строки укомплектування команди.
- Хибні спрацювання (false positives). На початковому етапі експлуатації IPS/IDS та SIEM можуть генерувати надмірну кількість сповіщень, що тимчасово збільшує навантаження на команду реагування, доки не буде відкалібровано правила кореляції.
- Залежність від постачальника (vendor lock-in). Використання пропріетарних ліцензій СУБД та SIEM ускладнює й здорожчує можливу заміну постачальника в майбутньому.
- Зростання вартості підписок. Ліцензійні моделі «за кінцеву точку» або «за обсяг даних» можуть суттєво здорожчати при масштабуванні бізнесу, що потребує щорічного перегляду бюджету на ІБ.

5.4 Обґрунтування інвестицій

Для оцінки доцільності інвестицій витрати на керування активом (12,44 млн грн за 5 років) варто порівнювати з потенційними втратами від реалізації ризиків, яких ці інвестиції покликані запобігти: простій платіжної системи, штрафи за недотримання PCI DSS та вимог НБУ, витрати на розслідування інциденту й повідомлення постраждалих клієнтів, а також репутаційні втрати, що впливають на відтік клієнтів. Навіть один запобігнутий інцидент середньої тяжкості з простоем платіжного сервісу на кілька днів здатен призвести до прямих і непрямих втрат, що перевищують річний бюджет на системи безпеки (близько 2,49 млн грн), що обґрунтовує розглянуті інвестиції як економічно виправдані.

6. Висновки

У результаті проведеного аналізу розраховано сукупну вартість володіння (TCO) ключовим активом — сервером бази даних платіжного процесингу — протягом п'ятирічного життєвого циклу, яка становить 6 185 000 грн, а з урахуванням витрат на системи інформаційної безпеки (SIEM, EDR, EPP, IPS, IDS, Firewall) — 12 440 000 грн.

Найбільшу частку витрат формує етап експлуатації та обслуговування (як активу, так і систем безпеки), що підкреслює важливість врахування операційних, а не лише капітальних витрат при плануванні бюджету на керування активами.

Підготовлений бізнес-кейс демонструє, що інвестиції у комплексний захист критичного активу є економічно обґрунтованими: вони знижують ймовірність і наслідки інцидентів безпеки, забезпечують відповідність регуляторним вимогам (PCI DSS, вимоги НБУ) та підвищують операційну ефективність, попри наявні ризики бюджетного, кадрового та технічного характеру. Таким чином, керівництву компанії «FinPay Ukraine» рекомендується затвердити поетапне фінансування описаного плану управління активом на наступний п'ятирічний період.